

Hands-on Lab: Enforcing Strong Password Policies

Lab Objectives

The lab is completed in a safe cloud environment. In this lab, I have used Kaspersky's password checker to check how vulnerable our passwords are. Using Local Group Policy Editor, I have also defined how to enforce strong password policies within the Microsoft Windows operating system.

In this hands-on lab, I have:

- Checked password strength.
- Reviewed Windows Local Group Policy Editor.
- Configured password policies.

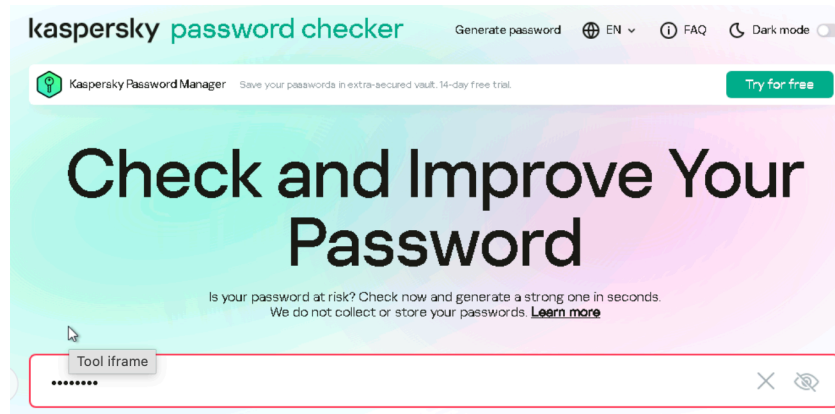
Part 1: Checked Password Strength

In the chrome search bar, I have searched for Kaspersky's password checker to test password strength. This tool showed me how safe a password is. It considered how long it would take an attacker to brute-force my password. It also compared my password to a database of leaked passwords that any attacker could have access to.

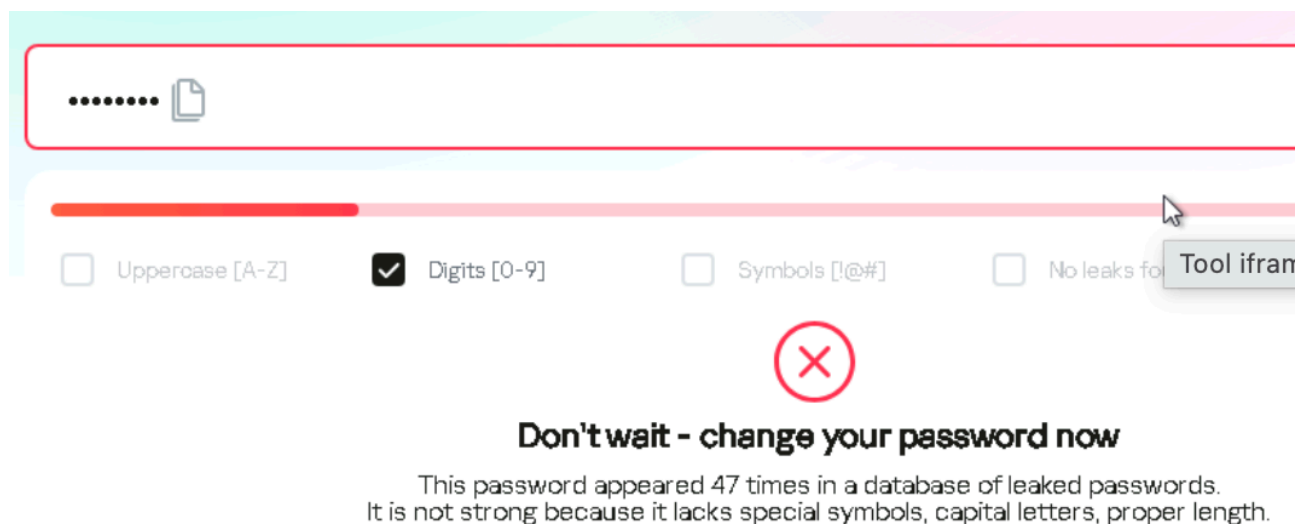
- Chrome icon to open the Chrome browser.
- Typed **password.kaspersky.com** into the address bar.



- I. First, I checked a password created by an imaginative user who was required to make a password using letters and numbers. The user used his pet's name and his year of birth so he could remember the password.
 - Clicked on "Test your password box" and typed "fido1973".
 - Enter



Straightway, Kaspersky provided feedback on the strength of the tested password.



I could see that the password does not have any uppercase. It just matched one criteria (0-9 digits). Kaspersky also said that the password appeared 47 times in a database leaked passwords. It advised to change the password.

II. Next, I entered a password created by a user who was required to create an 8-digit password using a capital letter, at least one number, and at least one symbol.

- Clicked "Test your password box" and typed "John001!".

- Kaspersky provided feedback on the strength of the tested password.

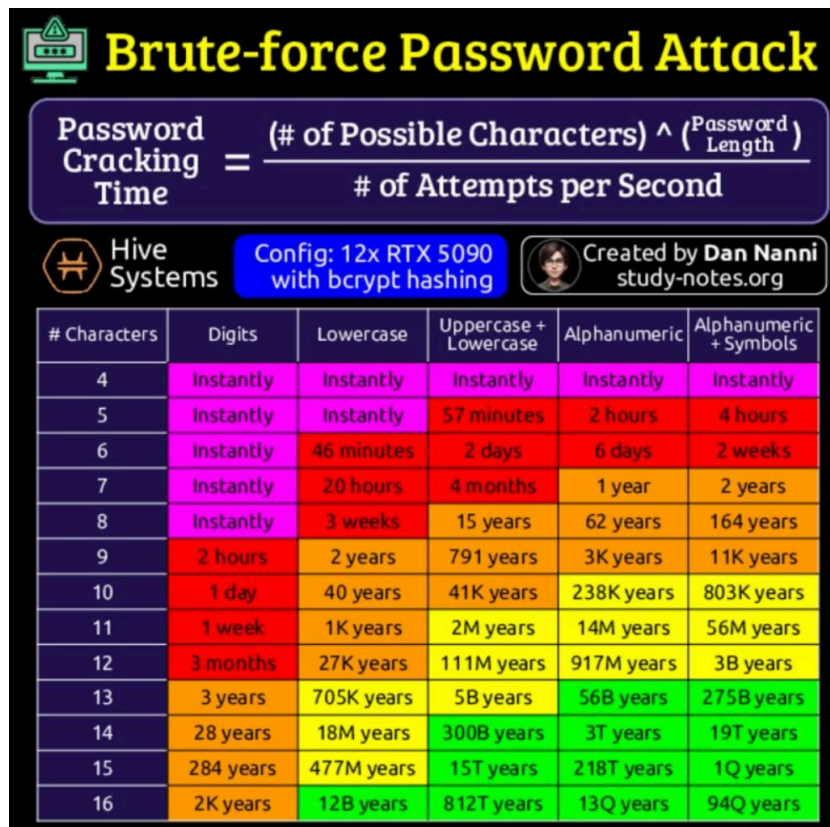
This time, I observed that the uppercase, digits, symbols were perfect. Kaspersky also showed that this password did not appear in leaked password database. However, it still suggested to change it as the length is too short.

III. Lastly, I tested a password created by a user who was required to create a 12-digit password using a capital letter, at least one number, and at least one symbol. Instead of using common words, they used the first letter of each word in a phrase they would remember. **Kenji liked lob star from 71 smith peter road which was £69!**

- Clicked “Test your password box” and typed “Kllsf7sprww£”. This time Kaspersky provided feedback on the strength of the tested password just like the previous one. It showed that although the password meets the criteria, still it needs to be changed because of short length.

What I learned?

From the above information, I have learned that less than 14 digits long password is not safe. It's not safe even if it would have mixed numbers, letters and special character. So, it should be more than 12 digits with mixed alphanumeric characters and special symbols. This way, it will be somewhat safe as it takes longer for the attackers to break the password.



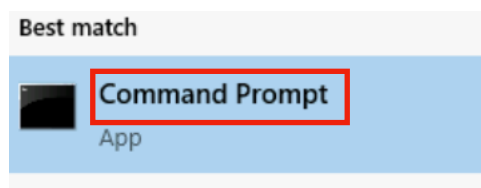
Source: LinkedIn

The reason why I am saying “somewhat safe” because the new RTX 5090 got more speed to break the password than before (source: <https://www.kaspersky.co.uk/blog/passwords-hacking-research-2026/30552/>). The safe way is to use the Multi Factor Authentication with Password Manager or Single Sign On (SSO).

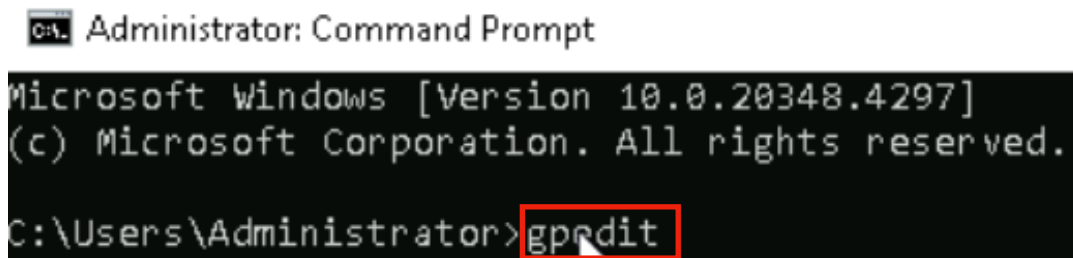
Part 2: Reviewed Windows Local Group Policy Editor

In this case, to enforce strong password policies for Windows users, I used the Local Group Policy Editor. The Local Group Policy Editor is a Microsoft Management Console (MMC) snap-in. It is very useful to configure and monitor Group Policies and user settings. To do this, I went to Windows Start menu:

- Typed **Command Prompt**
- Clicked on it

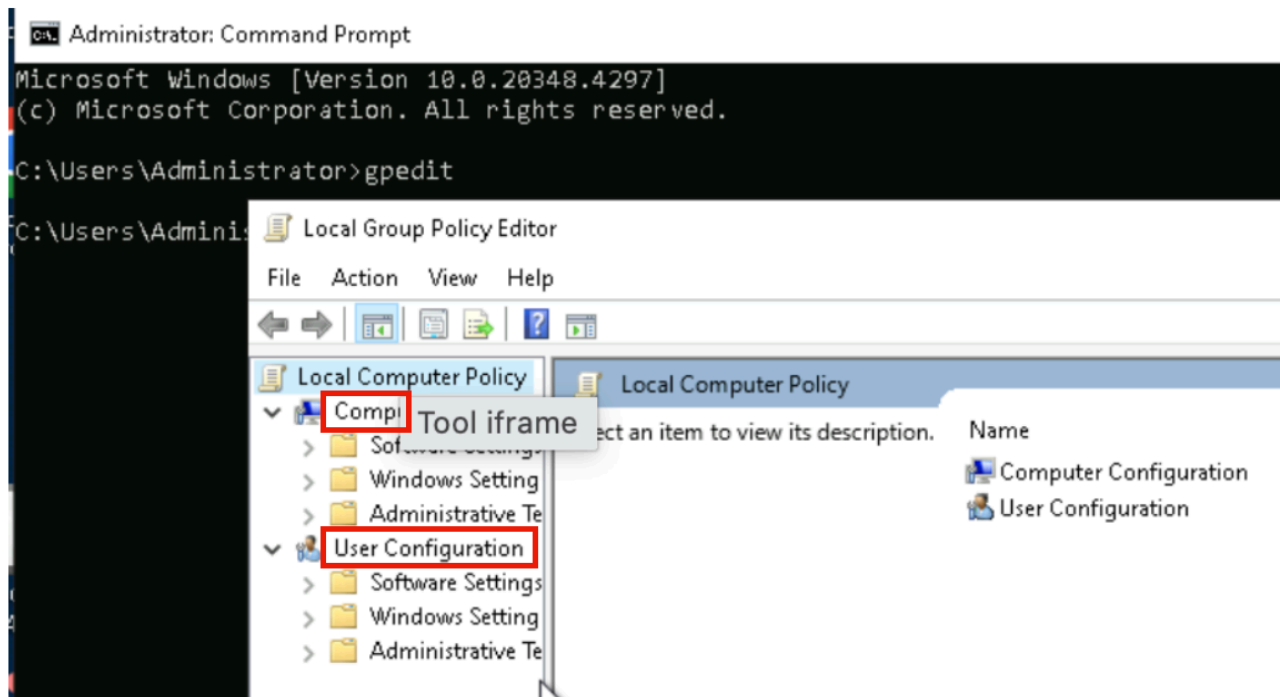


- Typed *gpedit* at the command prompt
- Pressed Enter.



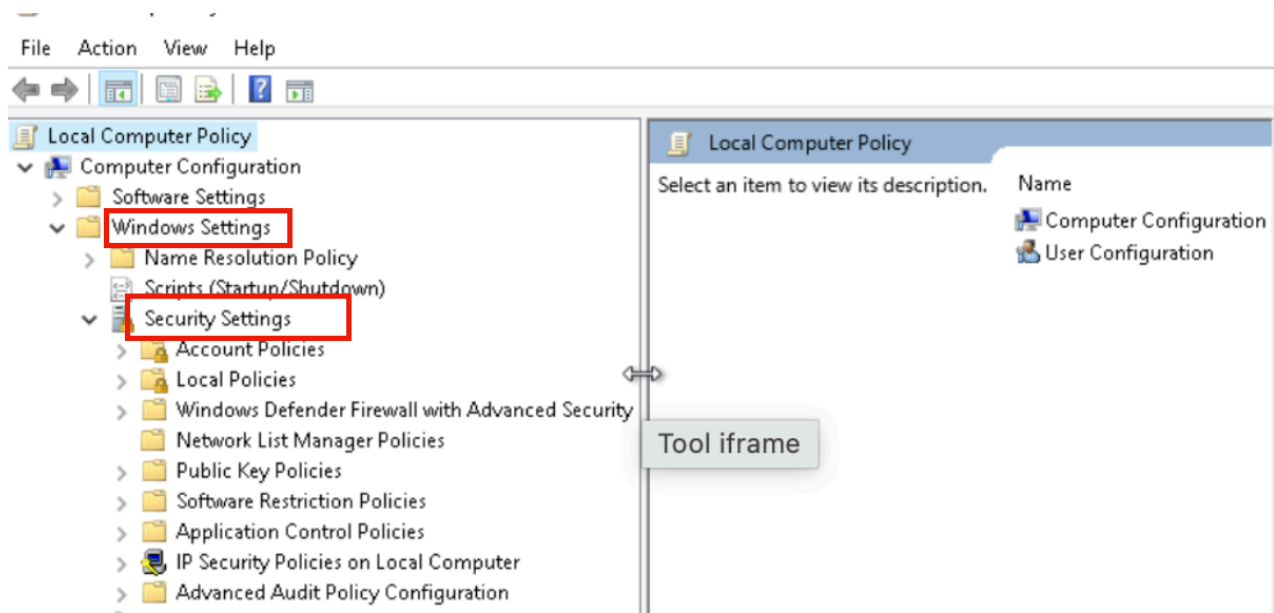
This opened the Local Group Policy Editor. Here I saw that the Local Computer Policy is broken into two configurations:

- Computer Configuration which holds settings that are applied to the computer when it is started.
- User Configuration which holds settings that are applied to users when they sign into the computer.

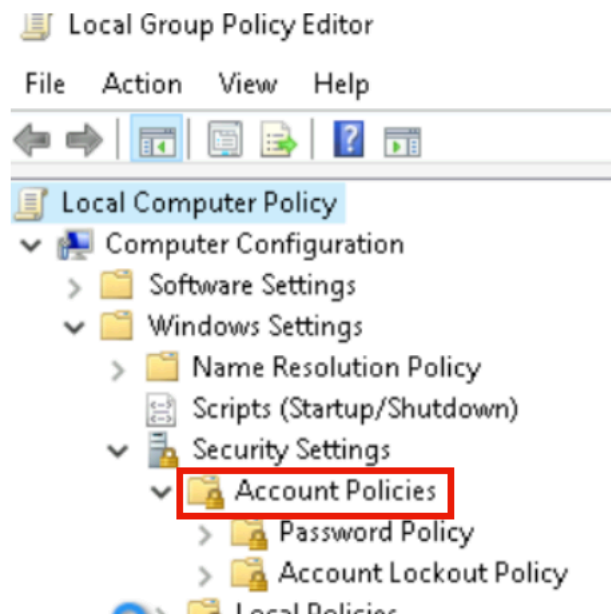


From here, I navigated to:

Computer Configuration > Windows Settings > Security Settings

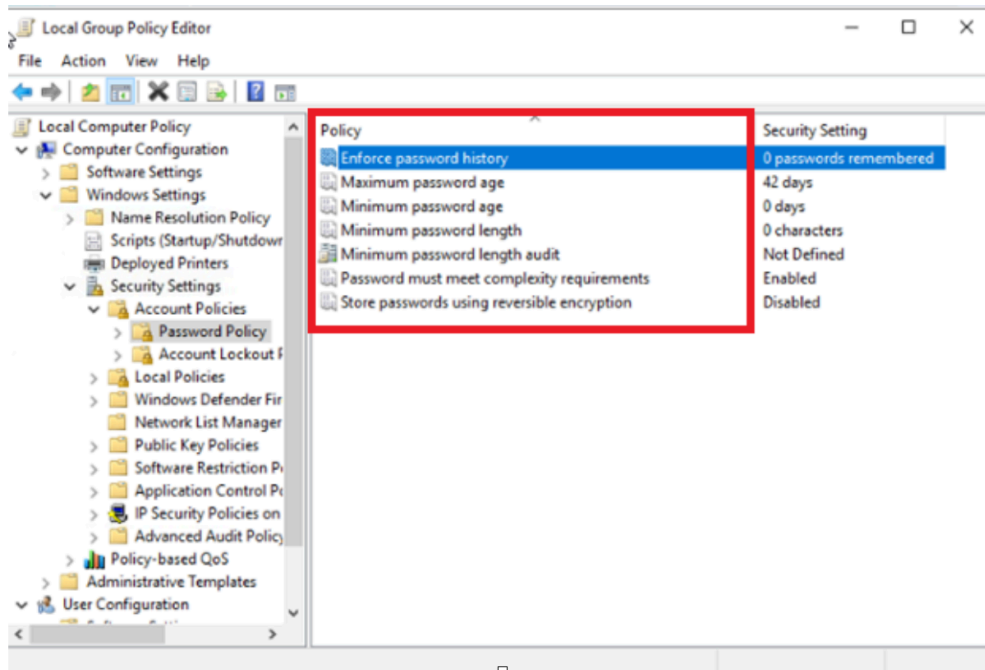


On the right panel, I saw several policy types along with a description of the types of policies included in that section. I expanded Account Policies folder to get the 'password policy' folder.



Next, under the **Account Policies** folder, I clicked the **Password Policy** folder. On the right pane, I saw **five** policies:

- **Enforce password history:** This policy determines how many unique passwords need to be used before an old password can be reused. Microsoft recommends this be set to 24.
- **Maximum password age:** This policy determines how many days a password can be used before the system requires a password change. Microsoft recommends that this be set somewhere between 30 and 90 days.
- **Minimum password age:** This policy determines how many days a password must be used before the system requires a change. Microsoft recommends this be set to one day.
- **Minimum password length:** This policy determines the fewest number of characters required in a password. Microsoft recommends that this be set somewhere between 8 and 14.
- **Minimum password length audit:** This policy is designed for organisations who want to track user password lengths. Microsoft recommends using this only in specific scenarios.
- **Password must meet complexity requirements:** This policy indicates that passwords must meet Windows Security complexity requirements. Microsoft recommends that complexity requirements be enabled, especially when no other policies are enforced, more complex, password policies.
- **Store passwords using reversible encryption:** This policy is specific to applications that use protocols requiring the user's password for authentication. Microsoft recommends that this option be disabled.



Part 3: Configured Password Policies

At this stage, I configured the following settings based on Microsoft recommendations:

- Enforce password history
- Maximum password age
- Minimum password age
- Minimum password length

1. Double-clicked **Enforce password history**.



2. Microsoft recommends that Enforce password history be set to **24**. I typed **24** into the box and clicked **OK**.



3. Double-clicked Maximum password age. It was set as **42** days.



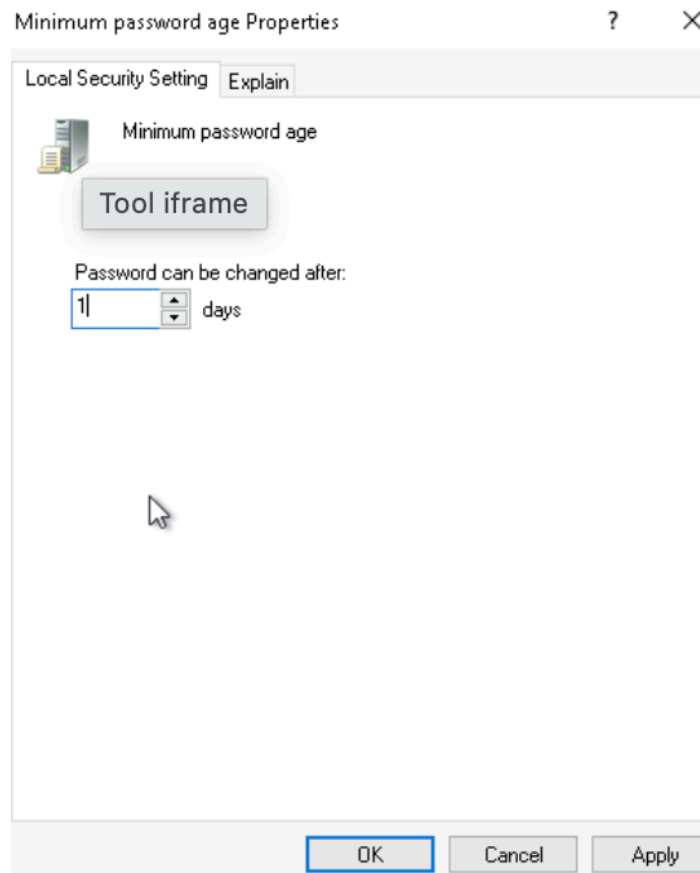
4. Microsoft recommends that passwords should be set to expire somewhere between **30** and **90** days. I typed **60** into the box and clicked **OK**.



5. Double-clicked **Minimum password age**.



6. Microsoft recommends that users should be required to wait at least one day before they can change their password. So, I typed **1** into the box and clicked **OK**.



Minimum password age	1 days
----------------------	--------

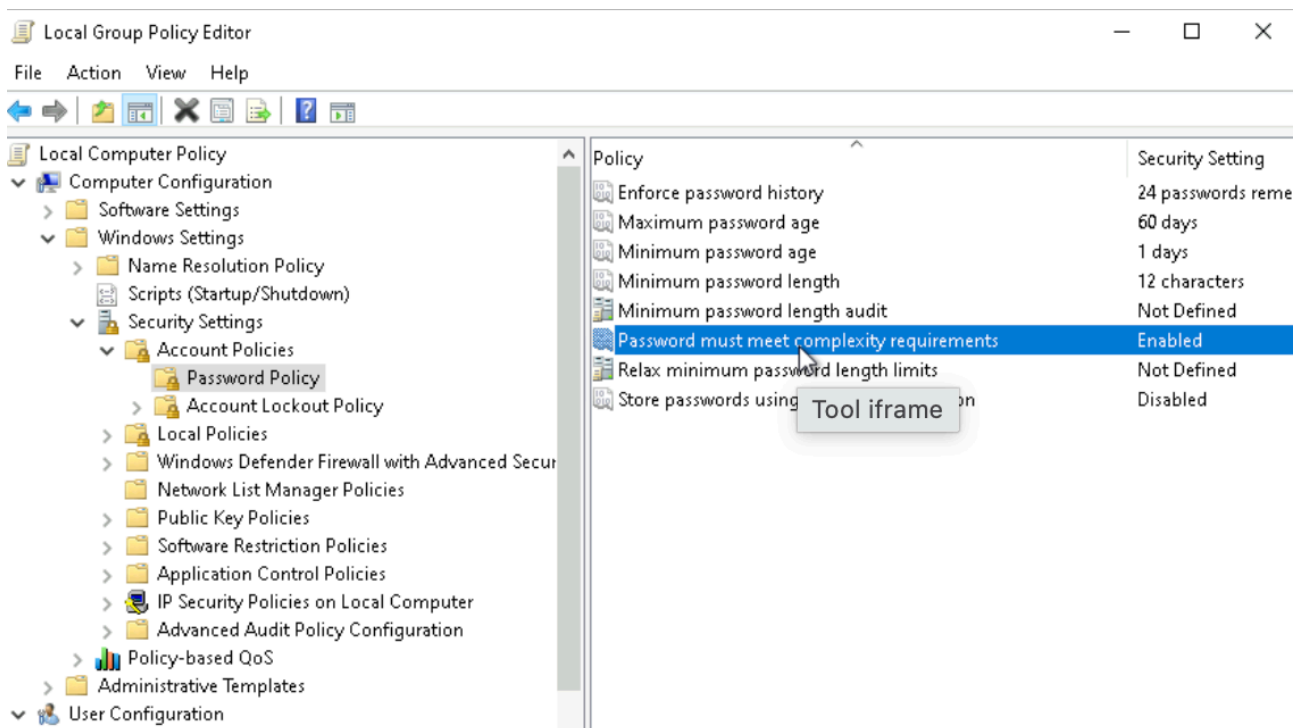
7. Double-clicked **Minimum password length** which was set up as **0** characters.

Minimum password length	0 characters
Minimum password length audit	Not Defined

8. Microsoft recommends that passwords be at least 8 characters and no more than 14 characters. Here I typed **12** into the box and clicked **OK**.

Minimum password length	12 characters
Minimum password length audit	Not Defined

9. I noticed that all of my recent changes appeared under the **Security Setting preview** on the right pane.



Lesson Learned

Completing this lab reinforced several core defensive principles that directly translate to real SOC and incident response work. Although it was performed in a safe cloud environment, the workflow mirrored what analysts do when assessing password hygiene, validating policy enforcement, and reducing credential-related attack surfaces. Weak or predictable passwords remain one of the most common initial access vectors, and assessing password strength highlighted how easily poor credentials can be exploited. Reviewing and configuring password policies through the Local Group Policy Editor demonstrated how endpoint-level hardening directly reduces credential-based attack opportunities and improves the quality of authentication-related alerts analysts rely on.

The lab also emphasised the importance of consistent policy enforcement, as misconfigurations or policy drift can create actual security gaps during investigations. Finally, documenting each configuration step with clear evidence reflects professional SOC workflows, where accurate reporting and reproducible changes are essential for audits, handovers, and post-incident analysis.

Conclusion

This lab strengthen my practical understanding of hoe enforcing strong password policies directly supports effective SOC and incident response operations.